

ĐẠI HỌC QUỐC GIA TP HCM
TRƯỜNG ĐẠI HỌC KHOA HỌC TỰ NHIÊN
KHOA CÔNG NGHỆ THÔNG TIN



BÁO CÁO LAB 03

Đề tài: Mã hóa dữ liệu sử dụng các thuật toán mã hóa công khai

Môn học: Bảo mật cơ sở dữ liệu

Sinh viên thực hiện:

Lưu Đức Toàn 23120095

Nguyễn Xuân Duy 23120121

Đào Nguyễn Nguyễn 23120306

Giáo viên hướng dẫn:

Võ Hoàng Phúc Khang

Ngày 1 tháng 5 năm 2026

Mục lục

I	Giới thiệu	2
1	Bảng phân công việc	2
2	Tổng quan bài lab	2
II	Nội dung thực hành	3
1	Phương pháp xây dựng Stored Procedure	3
1.1	Quy trình xây dựng Stored Procedure thêm mới dữ liệu	3
1.2	Quy trình xây dựng Stored Procedure truy vấn dữ liệu	3
1.3	Đánh giá phương pháp	4
2	Màn hình đăng nhập	4
2.1	Quản lý kết nối và phiên làm việc (Session)	4
2.2	Kiểm thử chức năng đăng nhập	4
3	Chức năng quản lý danh mục lớp học	6
3.1	Stored Procedure	6
3.2	Kiểm thử chức năng thao tác dữ liệu	6
4	Chức năng quản lý danh sách sinh viên	8
4.1	Cơ chế bảo mật và xử lý dữ liệu bằng Stored Procedure	8
4.2	Phân quyền và Ràng buộc dữ liệu (Validation) trên giao diện	8
4.3	Kiểm thử chức năng quản lý sinh viên	9
5	Chức năng quản lý và mã hóa bảng điểm	12
5.1	Cơ chế Mã hóa bằng Stored Procedure	12
5.2	Kiểm thử chức năng mã hóa điểm	13
6	Theo dõi và Đánh giá bảo mật bằng SQL Server Profiler	13
6.1	Hướng dẫn cấu hình SQL Server Profiler	14
6.2	Kết quả theo dõi và Giải thích	14
6.3	Nhận xét Đánh giá bảo mật	14
	Tài liệu tham khảo	16

I Giới thiệu

1 Bảng phân công việc

STT	MSSV	Phân công	Hoàn thành
1	23120095	d 2 ý đầu, e	100%
2	23120121	a, b, c	100%
3	23120306	d 2 ý sau	100%

2 Tổng quan bài lab

Trong bối cảnh an toàn thông tin ngày càng trở nên quan trọng, việc bảo vệ dữ liệu nhạy cảm trong các hệ thống cơ sở dữ liệu là một yêu cầu thiết yếu. Bài lab này tập trung vào việc tìm hiểu và ứng dụng các kỹ thuật mã hóa dữ liệu sử dụng thuật toán mã hóa công khai, tiêu biểu là thuật toán RSA (Rivest–Shamir–Adleman).

Mục tiêu chính của bài thực hành chính là nắm được quy trình triển khai mã hóa trong môi trường cơ sở dữ liệu, từ việc tạo và quản lý khóa, đến việc áp dụng mã hóa dữ liệu và xây dựng các cơ chế truy vấn phù hợp. Cụ thể, bài lab bao gồm các nội dung chính như:

- Tạo cặp khóa công khai và khóa bí mật phục vụ cho việc mã hóa và giải mã dữ liệu.
- Xây dựng bảng dữ liệu chứa các thông tin cần được bảo vệ và thực hiện mã hóa dữ liệu trước khi lưu trữ.
- Áp dụng thuật toán RSA để đảm bảo dữ liệu được mã hóa an toàn, chỉ có thể giải mã bởi các đối tượng được cấp quyền.
- Xây dựng stored procedure để truy vấn và xử lý dữ liệu đã mã hóa, đảm bảo tính bảo mật nhưng vẫn đáp ứng được yêu cầu khai thác thông tin.

Thông qua bài lab, không chỉ hiểu rõ hơn về nguyên lý hoạt động của mã hóa công khai mà còn biết cách ứng dụng vào thực tế, đặc biệt trong việc bảo vệ dữ liệu trong hệ quản trị cơ sở dữ liệu. Đây là nền tảng quan trọng để phát triển các hệ thống thông tin an toàn và đáng tin cậy trong môi trường thực tế.

II Nội dung thực hành

1 Phương pháp xây dựng Stored Procedure

Trong bài lab này, hai Stored Procedure được xây dựng nhằm phục vụ cho việc thêm mới và truy vấn dữ liệu nhân viên trong điều kiện dữ liệu được bảo vệ bằng các kỹ thuật mã hóa. Quy trình thực hiện được thiết kế theo hướng đảm bảo tính bảo mật nhưng vẫn cho phép khai thác thông tin khi cần thiết.

1.1 Quy trình xây dựng Stored Procedure thêm mới dữ liệu

Đối với chức năng thêm mới nhân viên, hệ thống thực hiện các bước chính như sau:

- **Tiếp nhận dữ liệu đầu vào:** Người dùng cung cấp các thông tin bao gồm mã nhân viên, họ tên, email, lương cơ bản, tên đăng nhập và mật khẩu.
- **Xử lý bảo mật mật khẩu:** Mật khẩu không được lưu trực tiếp mà được chuyển qua hàm băm SHA2_512. Kết quả băm này sẽ được lưu vào cơ sở dữ liệu nhằm đảm bảo không thể khôi phục lại mật khẩu ban đầu.
- **Tạo và quản lý khóa RSA:** Từ mật khẩu người dùng cung cấp, hệ thống sử dụng để tạo khóa bất đối xứng (bao gồm khóa công khai và khóa bí mật). Khóa công khai được đặt tên trùng với mã nhân viên để dễ quản lý.
- **Mã hóa dữ liệu lương:** Giá trị lương cơ bản trước khi lưu sẽ được mã hóa bằng khóa công khai RSA. Điều này đảm bảo rằng dữ liệu lương không thể đọc được nếu không có khóa bí mật tương ứng.
- **Lưu trữ dữ liệu:** Sau khi hoàn tất các bước mã hóa, dữ liệu sẽ được ghi vào bảng **NHANVIEN**, bao gồm mật khẩu đã băm, lương đã mã hóa và tên khóa công khai.

1.2 Quy trình xây dựng Stored Procedure truy vấn dữ liệu

Đối với chức năng truy vấn thông tin nhân viên, hệ thống thực hiện theo các bước:

- **Xác thực người dùng:** Người dùng cung cấp tên đăng nhập và mật khẩu. Mật khẩu này được sử dụng để xác định khóa bí mật tương ứng.

- **Truy xuất dữ liệu:** Hệ thống tìm kiếm thông tin nhân viên dựa trên tên đăng nhập.
- **Giải mã dữ liệu lương:** Giá trị lương đã được mã hóa trước đó sẽ được giải mã bằng khóa bí mật tương ứng với người dùng.
- **Trả kết quả:** Hệ thống trả về các thông tin gồm mã nhân viên, họ tên, email và lương đã được giải mã về dạng ban đầu.

1.3 Đánh giá phương pháp

Phương pháp này đảm bảo các yêu cầu về bảo mật dữ liệu:

- Mật khẩu được bảo vệ bằng hàm băm một chiều, tránh bị lộ ngay cả khi cơ sở dữ liệu bị truy cập trái phép.
- Dữ liệu lương được mã hóa bằng thuật toán bất đối xứng, chỉ có thể giải mã khi có khóa bí mật hợp lệ.
- Việc gắn khóa công khai với mã nhân viên giúp dễ dàng quản lý và mở rộng hệ thống.

2 Màn hình đăng nhập

Chức năng đăng nhập được thiết kế nhằm đảm bảo tính bảo mật trong việc xác thực người dùng. Quá trình kiểm tra thông tin đăng nhập không được thực hiện trực tiếp trên mã nguồn ứng dụng mà được giao phó cho cơ sở dữ liệu thông qua thủ tục `SP_SEL_PUBLIC_NHANVIEN`.

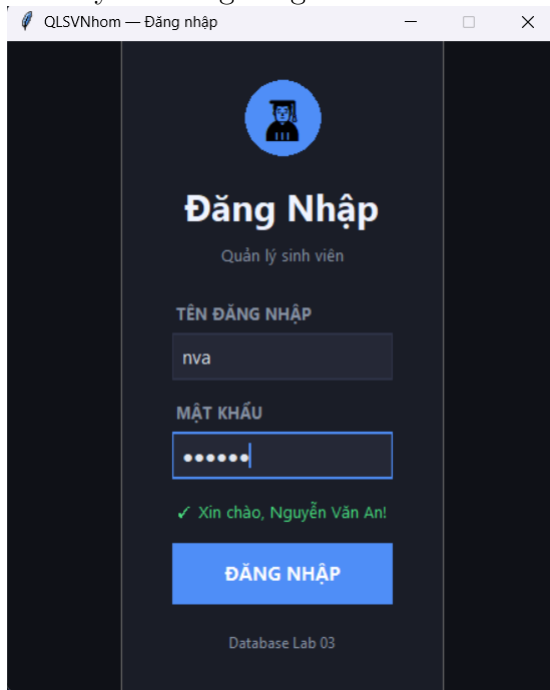
2.1 Quản lý kết nối và phiên làm việc (Session)

Ứng dụng sử dụng chuỗi kết nối chuẩn qua ODBC driver. Sau khi `SP_SEL_PUBLIC_NHANVIEN` trả về kết quả hợp lệ, các thông tin định danh của người dùng (như Mã nhân viên, Họ tên, Lương) được lưu trữ vào bộ nhớ tạm thời của ứng dụng (module `session.py`). Cơ chế này đóng vai trò duy trì trạng thái đăng nhập, cho phép phân quyền và cá nhân hóa dữ liệu hiển thị trên các biểu mẫu tiếp theo.

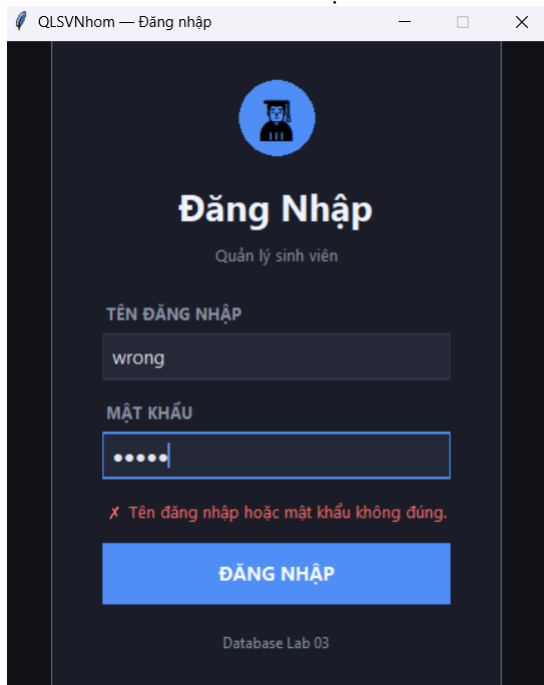
2.2 Kiểm thử chức năng đăng nhập

Các kịch bản kiểm thử được thực hiện nhằm đánh giá tính ổn định của chức năng:

- **Đăng nhập thành công:** Khi cung cấp thông tin hợp lệ, hệ thống thiết lập phiên làm việc và chuyển hướng sang màn hình chính.



- **Sai thông tin đăng nhập:** Ứng dụng hiển thị thông báo lỗi rõ ràng mà không làm lộ chi tiết cấu trúc cơ sở dữ liệu.



3 Chức năng quản lý danh mục lớp học

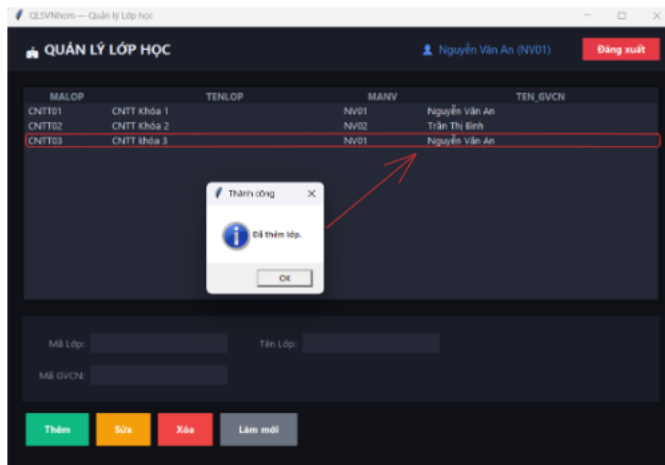
Màn hình quản lý lớp học cho phép người dùng thực hiện các thao tác thao tác với bảng LOP. Mọi thao tác làm thay đổi trạng thái dữ liệu đều được thực thi qua các Stored Procedures nhằm đảm bảo tính toàn vẹn và bảo mật.

3.1 Stored Procedure

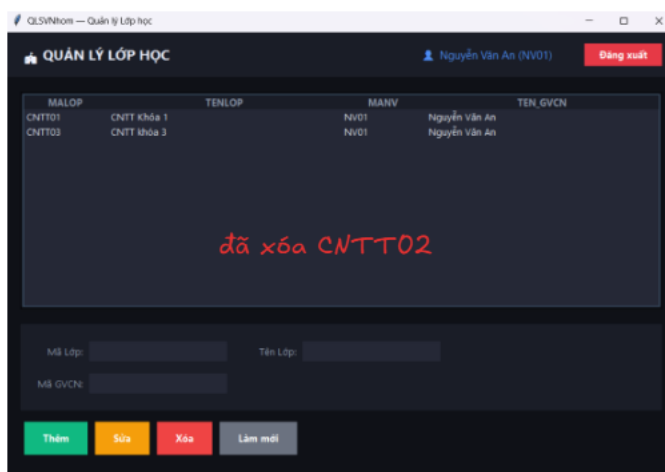
- **Truy xuất dữ liệu (SP_SEL_LOP):** Thủ tục này thực hiện truy vấn **SELECT** toàn bộ dữ liệu từ bảng LOP. Ứng dụng nhận kết quả dưới dạng danh sách các dòng và ánh xạ trực tiếp lên thành phần Treeview của giao diện.
- **Thêm mới dữ liệu (SP_INS_LOP):** Thủ tục tiếp nhận các tham số gồm Mã lớp, Tên lớp và Mã nhân viên quản lý. Trước khi thực thi lệnh **INSERT**, ứng dụng thực hiện kiểm tra tính hợp lệ của dữ liệu để đảm bảo không vi phạm ràng buộc toàn vẹn.
- **Cập nhật dữ liệu (SP_UPD_LOP):** Thủ tục này cho phép thay đổi thông tin Tên lớp hoặc Mã nhân viên quản lý dựa trên khóa chính là Mã lớp. Từ phía ứng dụng, khi người dùng chọn một lớp học để chỉnh sửa, trường Mã lớp trên giao diện được thiết lập ở trạng thái vô hiệu hóa (disabled). Việc này đảm bảo khóa chính không bị thay đổi trong quá trình thao tác, giúp lệnh **UPDATE** luôn ánh xạ đúng vào bản ghi gốc trong cơ sở dữ liệu.
- **Xóa dữ liệu (SP_DEL_LOP):** Thủ tục xóa nhận tham số đầu vào là Mã lớp và thực thi lệnh **DELETE**. Ứng dụng tích hợp cơ chế cảnh báo thông qua hộp thoại xác nhận (confirmation dialog) nhằm tránh việc xóa nhầm dữ liệu. Ngoài ra, việc xóa cũng phụ thuộc vào các ràng buộc khóa ngoại (ví dụ: lớp học không được chứa sinh viên), nếu vi phạm, thủ tục sẽ trả về lỗi và ứng dụng tiến hành bắt ngoại lệ để thông báo cho người dùng một cách an toàn.

3.2 Kiểm thử chức năng thao tác dữ liệu

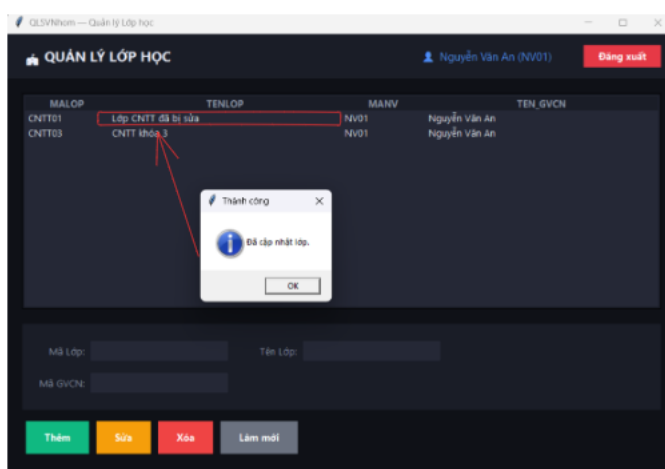
- **Thêm lớp học:** Dữ liệu nhập vào biểu mẫu được xác thực (validate) trước khi gọi thủ tục. Lớp học mới xuất hiện trên lưới dữ liệu ngay sau khi cơ sở dữ liệu phản hồi thành công.



- **Xóa lớp học:** Thao tác xóa hoạt động ổn định, dữ liệu được loại bỏ khỏi lưới hiển thị đồng thời với việc xóa trong cơ sở dữ liệu.



- **Cập nhật thông tin:** Tính năng khóa trường Mã lớp hoạt động đúng nguyên lý, bảo vệ tính toàn vẹn của khóa chính.



4 Chức năng quản lý danh sách sinh viên

Màn hình quản lý sinh viên được thiết kế theo cấu trúc điều hướng phân cấp (Hierarchical Navigation). Thay vì hiển thị toàn bộ sinh viên, người dùng bắt buộc phải chọn một lớp học từ màn hình Quản lý Lớp, sau đó nhấn nút "Quản lý Sinh viên" để truy cập vào danh sách sinh viên tương ứng của lớp đó.

4.1 Cơ chế bảo mật và xử lý dữ liệu bằng Stored Procedure

Các thủ tục thao tác dữ liệu với thực thể Sinh viên được bảo vệ nghiêm ngặt tại tầng cơ sở dữ liệu:

- **Truy xuất dữ liệu (SP_SEL_SINHVIEN):** Thủ tục này thực hiện truy vấn `SELECT` danh sách sinh viên dựa trên tham số Mã lớp. Ứng dụng nhận kết quả và ánh xạ lên thành phần Treeview để đảm bảo người dùng chỉ thao tác trên dữ liệu hợp lệ của lớp đã chọn.
- **Thêm mới dữ liệu (SP_INS_SINHVIEN):** Thủ tục tiếp nhận thông tin sinh viên và thực hiện hai lớp bảo vệ. Thứ nhất, kiểm tra mã nhân viên thao tác có đúng là chủ nhiệm lớp hay không để ngăn chặn hành vi leo thang đặc quyền. Thứ hai, tham số mật khẩu được băm bằng hàm `HASHBYTES('SHA2_512')` thành chuỗi nhị phân trước khi thực thi lệnh `INSERT`, đảm bảo dữ liệu không bị lộ.
- **Cập nhật dữ liệu (SP_UPD_SINHVIEN):** Cho phép thay đổi thông tin sinh viên (trừ khóa chính và mã lớp). Tương tự thêm mới, thủ tục đối chiếu quyền quản lý thông qua bảng `LOP`. Ở phía ứng dụng, trường Mã lớp và Mã sinh viên bị vô hiệu hóa (disabled) để bảo vệ tính toàn vẹn của dữ liệu trong quá trình thao tác lệnh `UPDATE`.
- **Xóa dữ liệu (SP_DEL_SINHVIEN):** Thủ tục nhận Mã sinh viên để thực thi lệnh `DELETE`. Nó tự động xóa các bản ghi phụ thuộc trong bảng `BANGDIEM` để tránh vi phạm ràng buộc khóa ngoại, đồng thời vẫn kiểm tra quyền chủ nhiệm trước khi thực thi để đảm bảo an toàn.

4.2 Phân quyền và Ràng buộc dữ liệu (Validation) trên giao diện

- **Phân quyền cấp độ màn hình (Screen-level Authorization):** Ngay khi màn hình danh sách sinh viên được khởi tạo, ứng dụng sẽ kiểm tra quyền của người dùng hiện tại. Nếu không phải là giảng viên chủ nhiệm, các nút thao tác dữ liệu (Thêm, Sửa, Xóa, Quản lý Điểm) sẽ bị vô hiệu hóa.

- **Ràng buộc dữ liệu từ Treeview:** Để ngăn chặn thao tác nhập liệu sai lệch, các chức năng Sửa, Xóa và xem Điểm được thiết kế để chỉ trích xuất dữ liệu trực tiếp từ dòng (row) đang được chọn trên lưới dữ liệu thay vì các ô nhập liệu tự do.

4.3 Kiểm thử chức năng quản lý sinh viên

- **Điều hướng và Hiển thị:** Danh sách sinh viên hiển thị đúng theo lớp đã chọn. Ô "Mã Lớp" được điền sẵn và khóa cứng để đảm bảo tính toàn vẹn dữ liệu.

MALOP	TENLOP	MANV	TEN_GVCN
CNTT01	Công nghệ thông tin Khóa 1	NV01	Nguyễn Văn An
CNTT02	Công nghệ thông tin Khóa 2	NV02	Trần Thị Bình
CNTT03	Công nghệ thông tin Khóa 3	NV03	Lê Hoàng Cường
CNTT04	Công nghệ thông tin Khóa 4	NV01	Nguyễn Văn An
CNTT05	Công nghệ thông tin Khóa 5	NV02	Trần Thị Bình
CNTT06	Công nghệ thông tin Khóa 6	NV03	Lê Hoàng Cường

Mã Lớp: Tên Lớp:

Mã GVCN:

QLSVNhom - Quản lý Sinh viên

QUẢN LÝ SINH VIÊN - LỚP CNTT01

Nguyễn Văn An (NV01)

Quản lý Lớp học

Đăng xuất

MASV	HOTEN	NGAYSINH	DIACHI	MALOP	TENDN
SV01	Đào Thanh Văn	2005-01-14	Quận 1, TP.HCM	CNTT01	sv01
SV02	Lê Thị Hương	2005-02-20	Quận 2, TP.HCM	CNTT01	sv02
SV03	Trần Văn Nam	2005-03-10	Quận 3, TP.HCM	CNTT01	sv03

Mã SV:

Họ Tên:

Ngày Sinh (YYYY-MM-DD):

Địa Chỉ:

Mã Lớp:

CNTT01

Tên Đăng Nhập:

Mật khẩu:

Thêm

Sửa

Xoá

Quản lý Điểm

Làm mới

- **Kiểm tra phân quyền:** Khi đăng nhập bằng tài khoản không có quyền chủ nhiệm lớp, các nút thao tác bị làm xám và vô hiệu hóa.

QLSVNhom - Quản lý Sinh viên

QUẢN LÝ SINH VIÊN - LỚP CNTT03

Nguyễn Văn An (NV01)

Quản lý Lớp học

Đăng xuất

MASV	HOTEN	NGAYSINH	DIACHI	MALOP	TENDN
SV07	Châu Văn Phát	2005-11-25	Quận 11, TP.HCM	CNTT03	sv07
SV08	Hồ Thị Anh	2005-12-01	Quận 12, TP.HCM	CNTT03	sv08
SV09	Ngô Văn Tài	2005-01-08	Bình Thạnh, TP.HCM	CNTT03	sv09

Mã SV:

Họ Tên:

Ngày Sinh (YYYY-MM-DD):

Địa Chỉ:

Mã Lớp:

CNTT03

Tên Đăng Nhập:

Mật khẩu:

Thêm

Sửa

Xoá

Quản lý Điểm

Làm mới

- **Cảnh báo chưa chọn dữ liệu:** Nhấn các nút thao tác khi chưa chọn một sinh viên cụ thể sẽ hiển thị hộp thoại cảnh báo yêu cầu chọn dữ liệu.

QLSVNhom - Quản lý Sinh viên

QUẢN LÝ SINH VIÊN - LỚP CNTT01 Nguyễn Văn An (NV01) [Quản lý Lớp học](#) [Đăng xuất](#)

MASV	HOTEN	NGAYSINH	DIACHI	MALOP	TENDN
SV01	Đào Thanh Văn	2005-01-14	Quận 1, TP.HCM	CNTT01	sv01
SV02	Lê Thị Hương	2005-02-20	Quận 2, TP.HCM	CNTT01	sv02
SV03	Trần Văn Nam	2005-03-10	Quận 3, TP.HCM	CNTT01	sv03

Thiếu thông tin

Vui lòng nhập đủ thông tin bắt buộc

[OK](#)

Mã SV: Họ Tên:

Ngày Sinh (YYYY-MM-DD): Địa Chỉ:

Mã Lớp: Tên Đăng Nhập:

Mật khẩu:

[Thêm](#) [Sửa](#) [Xoá](#) [Quản lý Điểm](#) [Làm mới](#)

5 Chức năng quản lý và mã hóa bảng điểm

Chức năng quản lý điểm được thiết kế dưới dạng một cửa sổ nổi (Popup), tập trung giải quyết bài toán bảo mật điểm thi thông qua thuật toán mã hóa phi đối xứng RSA được thực thi trực tiếp tại cơ sở dữ liệu.

5.1 Cơ chế Mã hóa bằng Stored Procedure

Thủ tục lưu điểm (SP_INS_BANGDIEM) áp dụng các kỹ thuật xử lý dữ liệu an toàn như sau:

- **Kiểm tra quyền truy cập:** Tương tự việc quản lý sinh viên, hệ thống truy vấn bảng LOP để xác thực quyền chủ nhiệm trước khi cho phép lưu hoặc cập nhật điểm thi.
- **Linh hoạt khóa mã hóa:** Thay vì dùng mã nhân viên tĩnh, hệ thống truy xuất PUBKEY thực sự của giảng viên từ bảng NHANVIEN để truyền vào `AsymKey_ID()`, hỗ trợ tốt cho việc xoay vòng khóa (Key Rotation) sau này.

- **Ép kiểu dữ liệu (Data Type Casting):** Để tuân thủ quy tắc của SQL Server, điểm thi (FLOAT) được chuyển tiếp qua chuỗi VARCHAR(50) trước khi dùng hàm EncryptByAsymKey mã hóa thành VARBINARY và thực thi lệnh INSERT / UPDATE xuống cơ sở dữ liệu.

5.2 Kiểm thử chức năng mã hóa điểm

- **Lưu điểm thi (Mã hóa):** Giảng viên điền mã học phần và điểm thi hợp lệ. Sau khi nhấn lưu, hệ thống báo thành công và điểm số lập tức được mã hóa bằng Public Key của giảng viên mà không cần xử lý thuật toán phức tạp tại tầng ứng dụng.

The screenshot displays the 'Quản lý Điểm' (Manage Scores) interface within the 'QL SVNhom - Quản lý Sinh viên' application. The main form is titled 'Quản lý Điểm' and contains the following elements:

- Header:** 'Điểm của SV: SV01' and a 'Xem Điểm' (View Score) button.
- Form Fields:**
 - MAHP (Subject Code):** HP01
 - DIEMTHI (Score):** 10
 - Save Button:** 'Lưu Điểm' (Save Score)
- Success Message:** A modal dialog box titled 'Thành công' (Success) with the message 'Đã lưu điểm.' (Score saved) and an 'OK' button.
- Background Table:** A table with columns 'MASV', 'MAHP', and 'DIEMTHI'. The first row shows 'SV01', 'HP01', and a long hexadecimal string representing the encrypted score.
- Navigation Buttons:** 'Thêm' (Add), 'Sửa' (Edit), 'Xoá' (Delete), 'Quản lý Điểm' (Manage Scores), and 'Làm mới' (Refresh).

6 Theo dõi và Đánh giá bảo mật bằng SQL Server Profiler

Trong phần này, công cụ SQL Server Profiler được sử dụng để theo dõi các câu lệnh truyền từ ứng dụng Python xuống cơ sở dữ liệu khi thực hiện chức năng thêm bảng điểm, nhằm kiểm chứng tính

an toàn của luồng thực thi và cơ chế mã hóa.

6.1 Hướng dẫn cấu hình SQL Server Profiler

- **Khởi tạo Trace:** Từ SQL Server Management Studio (SSMS), mở Tools → SQL Server Profiler và tạo một Trace mới.
- **Thiết lập Event Selection:** Để tránh nhiễu thông tin, tiến hành lọc các sự kiện không cần thiết. Chỉ chọn các sự kiện quan trọng thuộc nhóm *Stored Procedures* và *TSQL* bao gồm: **RPC:Completed** (bắt các Remote Procedure Call từ pyodbc) và **SP:Completed** (bắt trạng thái hoàn thành của Stored Procedure).
- **Thực thi theo dõi:** Nhấn Run để Profiler bắt đầu lắng nghe. Trở lại giao diện ứng dụng Python, tiến hành đăng nhập với tài khoản Giảng viên, chọn một sinh viên và thực hiện chức năng nhập điểm. Sau khi nhấn "Lưu Điểm", tạm dừng (Pause) Profiler để phân tích dữ liệu.

6.2 Kết quả theo dõi và Giải thích

Kết quả hiển thị trên bảng trace của SQL Server Profiler khi lưu điểm thành công:

SP:Completed	EXEC SP_INS_BANGDIEM @P1,@P2,@P3,@P4	Python
RPC:Completed	declare @p1 int set @p1=1 exec sp_...	Python
RPC:Completed	exec sp_unprepare 1	Python

- **Sự kiện RPC:Completed:** Hiển thị câu lệnh `declare @p1 int set @p1=1 exec sp_prepare...`. Điều này chứng tỏ ứng dụng Python sử dụng cơ chế prepare statement để chuẩn bị câu lệnh và truyền tham số một cách an toàn.
- **Sự kiện SP:Completed:** Ghi nhận lệnh gọi `EXEC SP_INS_BANGDIEM @P1, @P2, @P3, @P4`. Các tham số truyền vào tương ứng là Mã sinh viên, Mã học phần, Điểm thi và Mã nhân viên đăng nhập.

6.3 Nhận xét Đánh giá bảo mật

Dựa trên kết quả trace từ Profiler, ta có thể rút ra các nhận xét sau về khía cạnh bảo mật:

- **Phòng chống SQL Injection:** Việc ứng dụng (qua thư viện pyodbc) không gửi các lệnh INSERT/UPDATE thô mà sử dụng Remote Procedure Call với tham số hóa (Parameterized

queries) đã giúp hệ thống ngăn chặn hoàn toàn các cuộc tấn công SQL Injection từ phía Client.

- **Mã hóa điểm thi (Data at Rest):** Mặc dù tham số điểm thi từ ứng dụng gửi xuống là chuỗi số thực (Plaintext), quá trình mã hóa được thực thi an toàn **bên trong** cơ sở dữ liệu.
- **Đề xuất cải tiến (Data in Transit):** Dù dữ liệu được bảo vệ tốt ở trạng thái lưu trữ, điểm số trên đường truyền từ ứng dụng Python đến SQL Server vẫn là Plaintext. Để chống lại các kỹ thuật tấn công Man-in-the-Middle (MITM), cần thiết lập chứng chỉ SSL/TLS hoặc bật tùy chọn **Encrypt=yes** trong chuỗi kết nối ODBC để đảm bảo an toàn đường truyền.

Tài liệu tham khảo